API-Gateway Service Overview

Aspect	Responsibilities
Trust Boundary	Only entry point crossing from the public internet → internal mesh. All untrusted traffic ends here.
Authentication	Strict OIDC Authorization Code + PKCE. Validate JWT (kid lookup, jwks rotation). Enforce iss, aud, exp, sub, tenant_id. Detect token replay via jti/nonce. Implement rolling key rotation policy.
Authorization & Multi-Tenant Enforcement	Validate scopes (fine-grained RBAC). Enforce per-tenant isolation: tenant_id extracted **only** from JWT, never from input. Deny cross-tenant manipulation.
Transport Security	Enforce TLS 1.2/1.3, HSTS, ALPN. Redirect HTTP→HTTPS at edge only. No TLS termination inside cluster.
Rate Limiting / Anti-Abuse	Layered rate limits (IP, user, tenant, endpoint). Protect file uploads. Apply WAF rules, including SQLi/XSS/SSRF patterns.
Input Hardening	Validate request schemas, limit body size, block dangerous content types, enforce filename normalization, prevent path traversal.
Data Classification	Handles P0-P2 only. No sensitive document processing. Only metadata.
Network Controls	Allowed egress only to internal backends: ingestion-svc, scheduler-svc, auth-svc. Block direct DB/MinIO/RabbitMQ access. Traffic inside cluster enforced with mTLS (service mesh).
Secrets & Credentials	API gateway internal JWT signing keys stored in Vault (HSM-backed). Key rotation every 30-90 days. Idle token TTL < 15 min.
Traceability & Auditing	Correlation ID injected (trace-id). Structured logs with request context, tenant_id, scopes. Integrate with SIEM (Splunk/ELK/Loki).
Extra CTO Controls	API-level anomaly detection (per-tenant traffic deviation). Reverse-proxy hardening. Canary deployments.